

Northgate University

Information Security Incident Management Policy

An ISO/IEC 27001:2013 aligned document · Internal Use Only

Document Reference	NGU-POL-16.1
Version	1.0
Classification	Internal Use Only
Issue Date	01 June 2026
Policy Owner	Chief Information Security Officer
Approved By	Information Governance Board
Next Review Date	01 June 2027
Aligned Standard	ISO/IEC 27001:2013 — Annex A.16

1. Purpose

This policy defines how Northgate University ("the University") detects, reports, assesses, responds to, and learns from information security incidents, so that their impact is minimised and recurrence is prevented, in line with ISO/IEC 27001:2013 Annex A.16.

2. Scope

This policy applies to all information security events, weaknesses, and incidents affecting University information, systems, and services, and to all staff, students, contractors, and third parties. It covers incidents occurring on University and personal devices and in on-site, remote, and cloud-hosted environments.

3. Definitions

- **Information security event.** An identified occurrence that indicates a possible breach of policy, failure of controls, or previously unknown situation that may be security-relevant.
- **Information security weakness.** A vulnerability or control gap that could be exploited to cause an incident.
- **Information security incident.** One or more unwanted or unexpected events that compromise the confidentiality, integrity, or availability of information.
- **Personal data breach.** A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (UK GDPR).

4. Responsibilities and Procedures

The University maintains defined responsibilities and documented procedures for managing information security incidents. A designated Incident Response Team coordinates the response to significant incidents, supported by IT, the Data Protection Officer, and the relevant Information Asset Owners. Procedures are tested and kept current (ISO/IEC 27001:2013 A.16.1.1).

5. Reporting Events and Weaknesses

- All staff, students, contractors, and third parties must report suspected information security events, weaknesses, and incidents promptly through the designated reporting channel (A.16.1.2, A.16.1.3).
- Reporting in good faith is encouraged and supported; the University operates a no-blame approach to genuine reports.
- Suspected personal data breaches must be reported immediately so that regulatory timescales can be met.
- Users must not attempt to investigate or exploit a suspected weakness themselves.

6. Incident Classification

Confirmed incidents are assigned a severity to determine the level and urgency of response:

Severity	Description	Target Initial Response
Critical	Major breach or outage affecting Confidential information or critical services University-wide; serious legal, regulatory, or safety impact.	Within 1 hour
High	Significant incident affecting sensitive information or an important service, with serious but more contained impact.	Within 4 hours
Medium	Contained incident with moderate impact on a single team or service.	Within 1 business day
Low	Minor event or weakness with negligible impact.	Within 5 business days

7. Incident Response Lifecycle

Incidents are managed through the following stages:

- **Identification.** The event is detected and recorded.
- **Assessment and triage.** The event is assessed to confirm whether it is an incident and assigned a severity (A.16.1.4).
- **Containment.** Immediate action is taken to limit the impact and prevent further spread.
- **Eradication.** The cause is removed — for example, malware removed, compromised credentials reset, or the exploited vulnerability remediated.
- **Recovery.** Affected systems and services are restored to normal operation and verified.
- **Closure and review.** The incident is formally closed and a post-incident review conducted (A.16.1.5, A.16.1.6).

8. Collection of Evidence

Where an incident may lead to disciplinary action, legal proceedings, or regulatory investigation, relevant evidence is identified, collected, and preserved in a manner that maintains its integrity and an appropriate chain of custody (ISO/IEC 27001:2013 A.16.1.7).

9. Personal Data Breach Notification

Where an incident involves personal data, it is assessed without delay against the UK GDPR. If the breach is likely to result in a risk to individuals' rights and freedoms, it is reported to the Information Commissioner's Office (ICO) within 72 hours of the University becoming aware of it. Where the breach is likely to result in a high risk to individuals, affected individuals are informed without undue delay. The Data Protection Officer leads the assessment and any notification.

10. Post-Incident Review and Learning

Following significant incidents, a post-incident review identifies the root cause and lessons learned. Findings are used to improve controls, update the information security risk register, and inform awareness activities. Recurring or systemic issues are escalated to the Information Governance Board (A.16.1.6).

11. Roles and Responsibilities

- **Chief Information Security Officer (CISO).** Owns this policy, oversees incident management, and convenes the Incident Response Team for significant incidents.
- **Incident Response Team.** Coordinates assessment, containment, eradication, recovery, and review.
- **Data Protection Officer (DPO).** Leads the assessment and notification of personal data breaches.
- **Information Asset Owners (IAOs).** Support the response for incidents affecting their assets.
- **All staff, students, contractors, and third parties.** Report events and incidents promptly and cooperate with the response.

12. Compliance and Enforcement

Compliance with this policy is mandatory. Failure to report a known incident, or actions that obstruct a response, may result in disciplinary action and, for third parties, may constitute a breach of contract.

13. Related Policies and Standards

- Information Security Policy (NGU-POL-5.1)
- Access Control Policy (NGU-POL-9.1)
- Information Classification Policy (NGU-POL-8.2)
- Information Security Risk Management Policy (NGU-POL-IRM01)
- ISO/IEC 27001:2013 — Annex A.16; ISO/IEC 27035 (incident management guidance)
- UK GDPR and Data Protection Act 2018

14. Document Version History

Version	Date	Author	Summary of Change
1.0	01 June 2026	Chief Information Security Officer	Initial issue. Establishes the information security incident management lifecycle.